

What is a Cyber Attack?

A cyber attack is an unauthorized action targeting digital assets within an organization's network. It is directed at computer information systems, infrastructure, networks, or personal computing devices. Attackers typically carry out these activities with the intention of altering, destroying, or stealing sensitive and personal data.

There are two main types of cyber attacks which are passive and active. In passive attacks, attackers gain unauthorized access to a network and monitor or collect data without making any changes to it. In contrast, active attacks involve modifying, encrypting, or damaging data within the system.

Once access is gained, attackers may use additional attack methods such as malware or endpoint attacks to further exploit an organization's network. As more organizations adopt remote working models, networks have become more vulnerable to data theft and destruction.

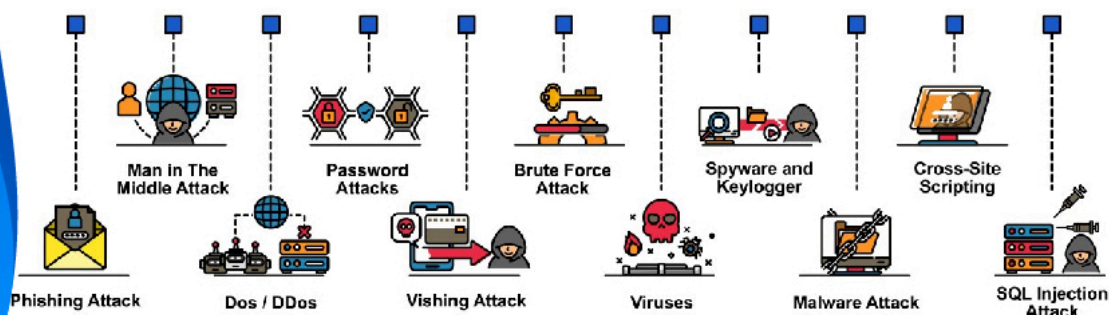
Who are the Most Common Targets?

The most common targets of cyber attacks include individuals, businesses, organizations, and even governments. Hackers often approach these targets through internal networks such as computers and electronic devices, or through human interaction using mobile devices, social networks, and software applications.

Types of Cyber Attacks Today

Depending on the type of cyber attack, the goals of hackers may vary slightly, but in general, they are all intended for illegal purposes. Below are some common types of cyber attacks along with their specific objectives.

CYBER SECURITY ATTACKS

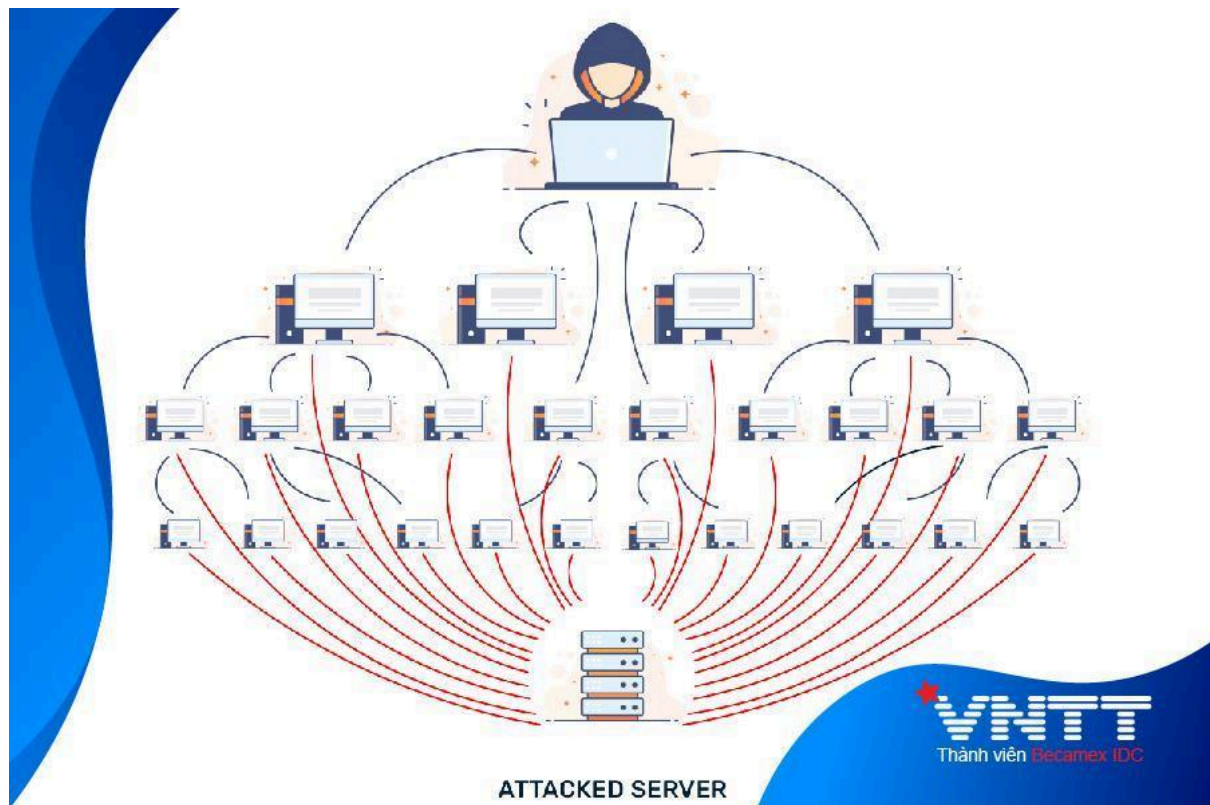


VNTT
Thành viên Decamex IDC

1. Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks

A Denial of Service attack is a type of cyber attack that exhausts a system's resources, making it unable to respond to legitimate service requests. The attacker overwhelms the target system by sending a large number of requests or exploiting system vulnerabilities, which leads to service disruption or complete unavailability.

A Distributed Denial of Service attack is similar in nature, as it also targets system resources. However, it is carried out using a large number of compromised hosts that are infected with malware and controlled by the attacker. These multiple sources generate massive traffic simultaneously, making the attack more powerful and difficult to mitigate compared to a standard Denial of Service attack.



Distributed Denial of Service Attacks

Unlike attacks designed to allow attackers to gain unauthorized access, a Distributed Denial of Service attack does not provide a direct benefit in terms of access or data theft. For some attackers, simply causing service disruption is sufficient satisfaction. However, if the targeted resources belong to a business competitor, the attack can provide indirect advantages. Another purpose of a Distributed Denial of Service attack is to take a system offline so that other types of attacks can be launched more easily, such as system hijacking.

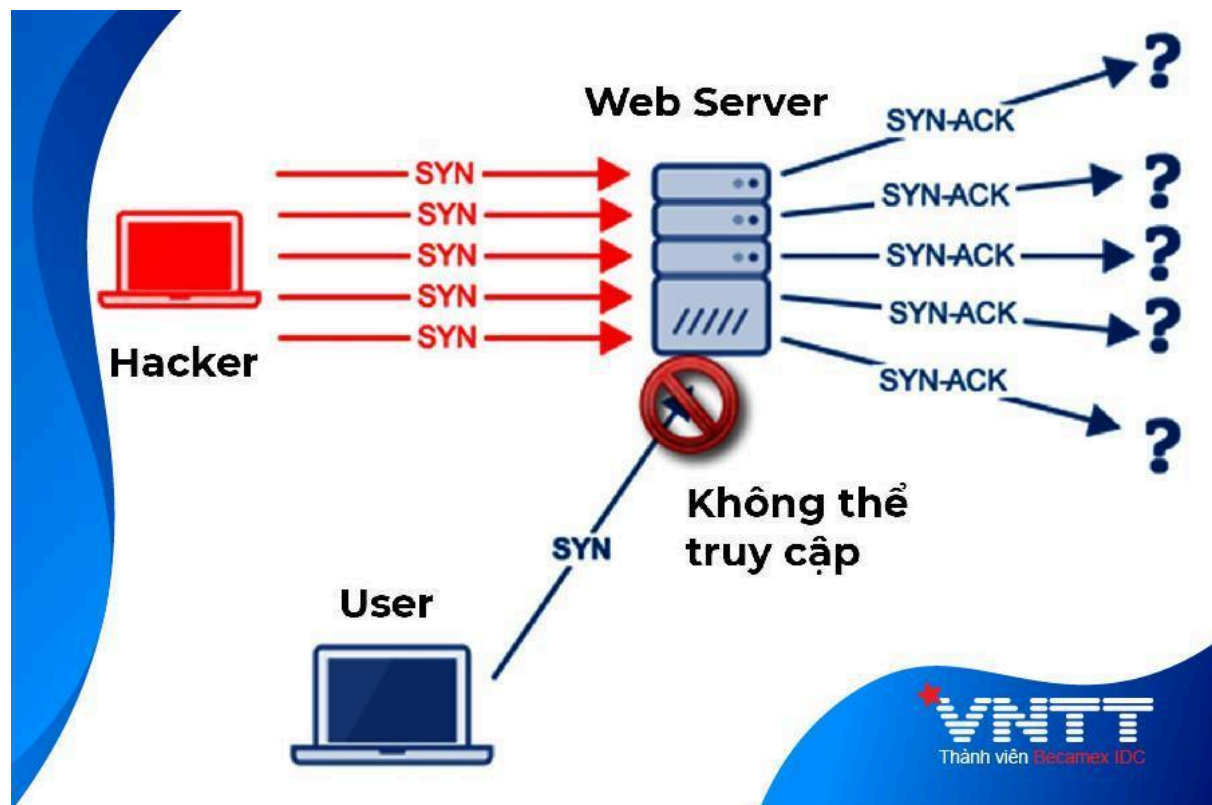
There are many types of Denial of Service and Distributed Denial of Service attacks. Some of the most common include TCP SYN flood attacks, Teardrop attacks, Smurf attacks, Ping of Death attacks, and botnet based attacks.

TCP SYN Flood Attack

In this type of attack, the attacker exploits the buffer memory used during the TCP handshake process, which is responsible for establishing a connection between two systems using the Transmission Control Protocol. The attacker sends a large number

of connection requests to the target system but does not respond to the acknowledgments returned by the system.

As a result, the target system continues to wait for responses that never arrive. This causes the connection queue to become full, eventually exhausting system resources and making the service slow, unstable, or completely unavailable.



Tấn công TCP SYN flood

Countermeasures Against TCP SYN Flood Attacks

There are several methods to mitigate TCP SYN flood attacks. One approach is to place servers behind a properly configured firewall that can filter or block suspicious SYN packets before they reach the system. Another method is to increase the size of the connection queue and reduce the timeout duration for incomplete connections. These measures help the system handle a larger number of requests and prevent the queue from being quickly exhausted.

Teardrop Attack

A Teardrop attack exploits vulnerabilities in the way operating systems handle fragmented Internet Protocol packets. In this attack, the attacker sends a series of IP fragments with overlapping offset and length fields. When the target system attempts to reassemble these malformed packets, the process fails due to inconsistencies in the fragment data.

As a result, the system becomes confused during packet reconstruction, which can lead to system instability, crashes, or complete system failure.



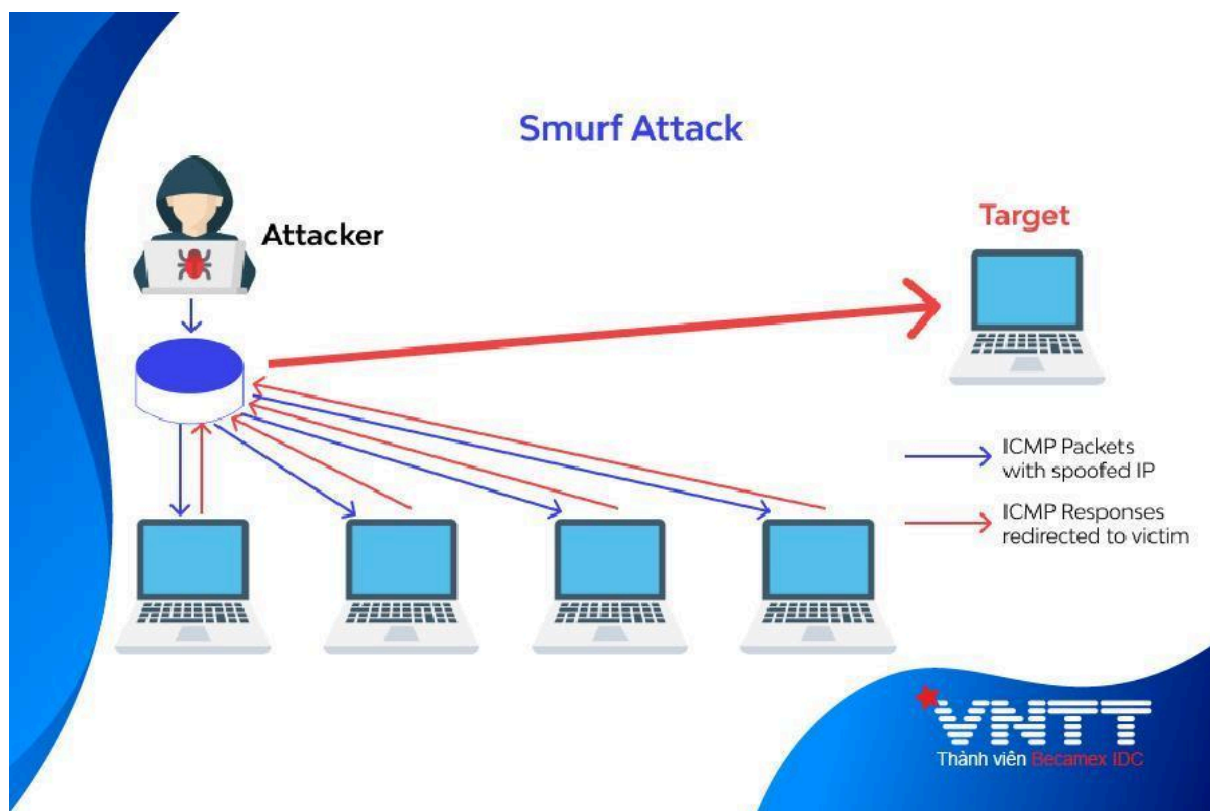
Tấn công Teardrop

If users do not have patches available to protect against this type of Distributed Denial of Service attack, they should disable SMB version 2 and block ports 139 and 445. These measures help reduce the risk of exploitation through vulnerable network services.

Smurf Attack

A Smurf attack involves the use of IP spoofing combined with Internet Control Message Protocol to flood a target network with excessive traffic. In this method, the attacker sends ICMP echo requests to network broadcast addresses rather than a single host.

These ICMP requests appear to originate from a spoofed victim address. As a result, multiple devices on the network respond simultaneously to the victim, generating a large volume of traffic that overwhelms the target system and leads to service disruption.



Smurf attack

For example, if the intended victim's IP address is 10.0.0.10, the attacker may spoof ICMP echo requests to appear as if they originate from 10.0.0.10 and send them to the broadcast address 10.255.255.255. This request is then delivered to all hosts within the network range, and each device sends a response back to 10.0.0.10. As a result, the victim is overwhelmed by a massive volume of incoming traffic, which can disrupt or

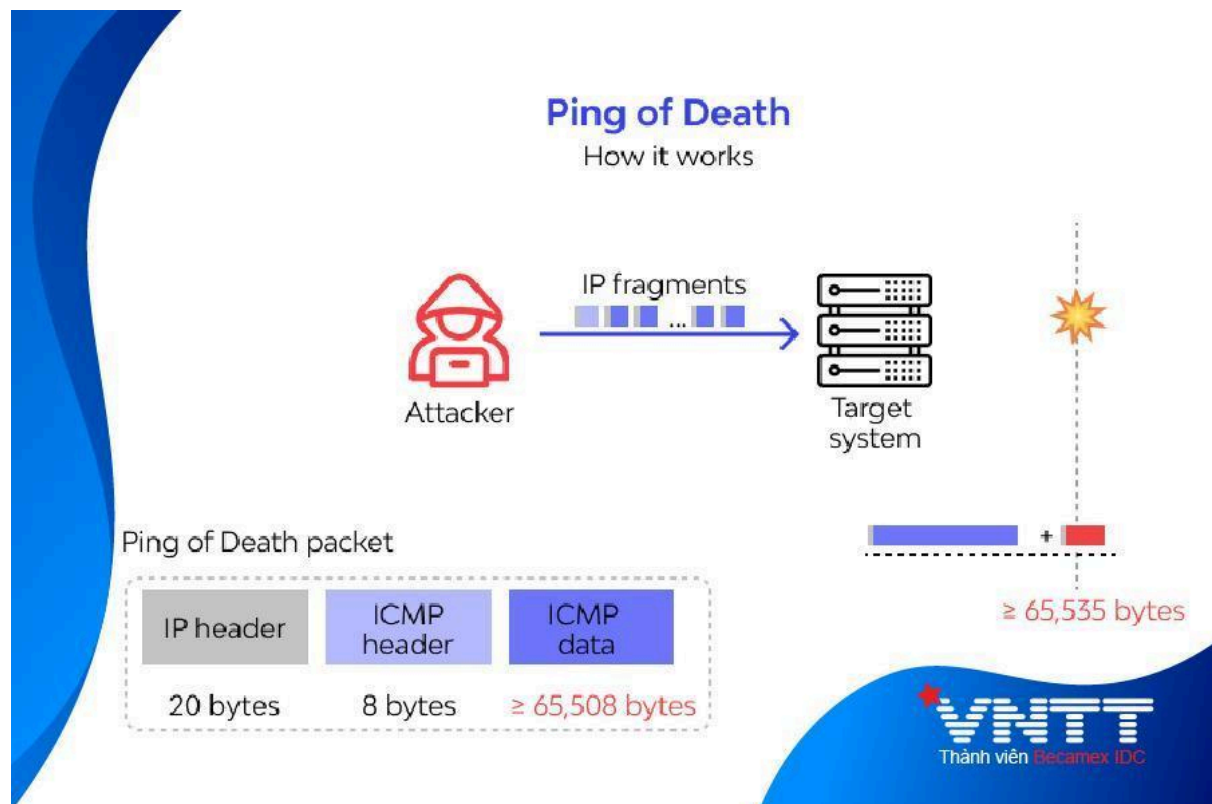
disable the network. This process can be repeated and automated to generate severe network congestion.

To protect systems from this type of attack, network administrators should disable direct IP broadcast forwarding on routers. This prevents ICMP echo requests from being broadcast across the network. Another approach is to configure end systems so that they do not respond to ICMP packets sent to broadcast addresses.

Ping of Death Attack

This type of attack involves sending IP packets to a target system with a size that exceeds the maximum allowable limit of 65,535 bytes. Since such oversized packets are not permitted, the attacker fragments them into smaller pieces before transmission.

When the target system attempts to reassemble these fragments, it may experience buffer overflow and other system errors. This can lead to system crashes, instability, or denial of service.



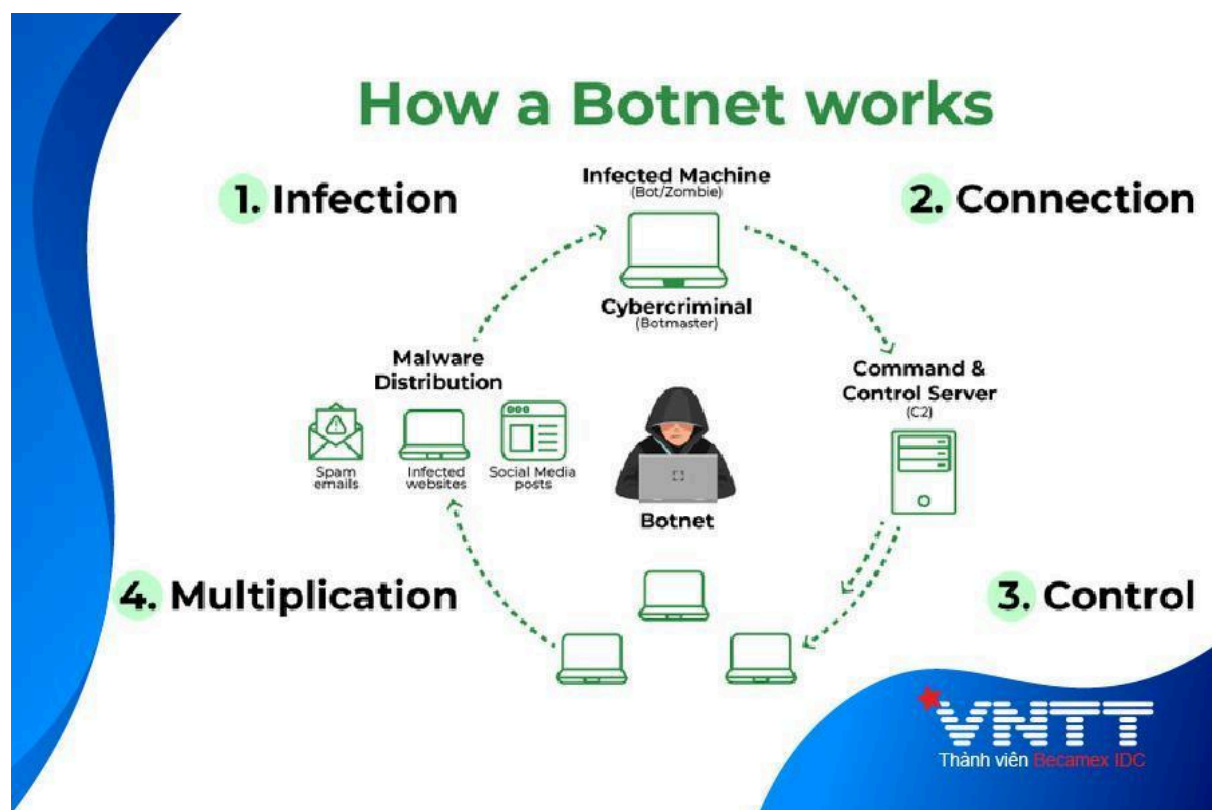
Ping of Death attack

Ping of Death attacks can be mitigated by using a firewall to inspect fragmented IP packets and ensure they do not exceed the maximum allowed size. This helps prevent malicious oversized packets from being reassembled and causing system failures.

Botnets

A botnet is a network of millions of systems infected with malware and controlled by an attacker to carry out Distributed Denial of Service attacks. These bots, also known as zombie systems, are used to launch coordinated attacks against a target system, often overwhelming its bandwidth and processing capacity.

Such Distributed Denial of Service attacks are difficult to trace because the botnet devices are distributed across multiple geographic locations, making it challenging to identify the true source of the attack.



Tấn công Botnets

Botnet Mitigation Techniques

Botnet attacks can be mitigated using several approaches. One method is RFC3704 filtering, which rejects traffic originating from spoofed addresses and ensures that incoming traffic can be traced back to its legitimate source network. For example, RFC3704 filtering allows packets only from valid address ranges and blocks those from illegitimate or bogon address spaces.

Another method is black hole filtering, which reduces unwanted traffic before it enters the protected network. When a Distributed Denial of Service attack is detected, a Border Gateway Protocol server sends routing updates to Internet Service Provider routers. These routers then redirect all malicious traffic destined for the target servers to a null interface, effectively discarding it and preventing the attack from reaching the network.

2. Man in the Middle Attacks

A Man in the Middle attack occurs when an attacker inserts themselves between the communication of a client and a server. This allows the attacker to intercept, modify, or manipulate the exchanged data without the knowledge of either party.

Session Hijacking

In this type of Man in the Middle attack, the attacker takes control of an active session between a client and a trusted server. A typical attack scenario may proceed as follows.

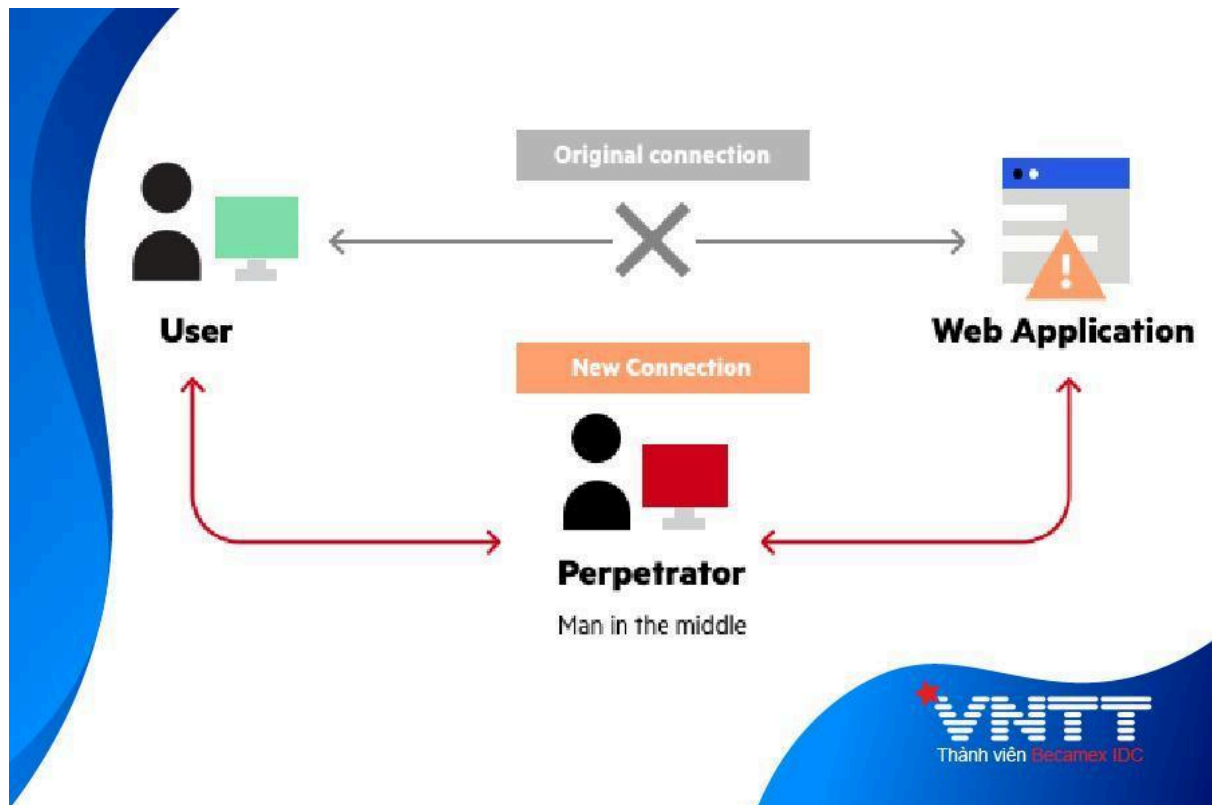
The client establishes a connection with the server.

The attacker gains control over the client system.

The attacker disconnects the client from the server.

The attacker replaces the client's IP address with their own and forges the client's sequence number.

The attacker continues communication with the server while the server believes it is still communicating with the legitimate client.



Tấn công Session hijacking

IP Spoofing

IP spoofing is a technique used by attackers to convince a system that it is communicating with a trusted and known entity, thereby gaining unauthorized access to the system. The attacker sends packets with a forged source IP address, typically that of a trusted server, instead of their own. The target host may accept these packets and act upon them, believing they originate from a legitimate source.

Replay Attack

A replay attack occurs when an attacker intercepts and stores valid data transmissions and later retransmits them while impersonating one of the original participants. This type of attack can be effectively mitigated by using timestamps or nonce values, which are random or time based numbers that ensure each communication session is unique and cannot be reused.

At present, there is no single technology or configuration that can completely prevent all Man in the Middle attacks. In general, encryption and Secure Sockets Layer certificates provide effective protection by ensuring both confidentiality and integrity of communications. However, in some cases, attackers may still position themselves between communicating parties in ways that encryption alone cannot fully prevent.

3. Spear Phishing Attack

Spear phishing is a targeted form of phishing in which attackers send emails that appear to come from trusted sources with the goal of obtaining sensitive information or persuading users to perform specific actions. These emails may contain attachments that, when opened, install malware on the victim's system.

They may also include links to fraudulent websites designed to trick users into downloading malicious software or revealing personal and confidential information.



Tấn công Spear-Phishing

Spear phishing is a form of targeted phishing activity. Attackers invest time in researching their targets and crafting messages that are highly personalized and relevant. As a result, these attacks can be very difficult to detect and even harder to defend against.

One of the simplest methods used in spear phishing attacks is email spoofing. In this technique, the information in the “From” field of an email is forged to make it appear as though it was sent by someone the recipient knows, such as a manager or a business partner.

Another technique used by attackers to increase credibility is website cloning. In this approach, attackers replicate legitimate websites in order to deceive victims into entering sensitive information, such as Personally Identifiable Information or login credentials.

To reduce the risk of falling victim to phishing attacks, several techniques can be applied:

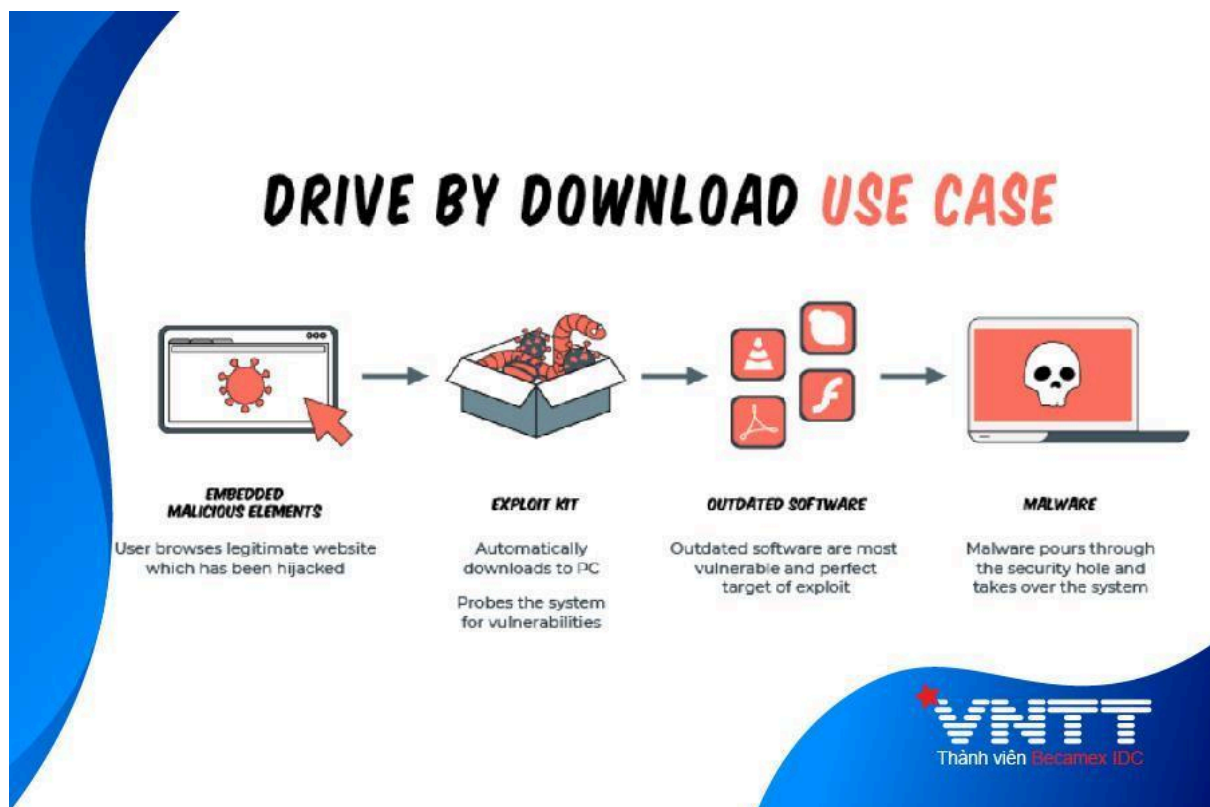
- Critical thinking is essential. Users should not assume that an email is legitimate simply because it appears attractive or urgent, especially when dealing with a large number of unread messages. It is important to pause and carefully evaluate the content of the email before taking any action .
- Link verification is another important technique. Users should hover over links without clicking on them in order to see the actual destination. By examining the URL carefully, users can identify suspicious or misleading links.
- Analyzing email headers can also help detect phishing attempts. Email headers provide information about how a message was routed to the recipient. Fields such as Reply to and Return Path should correspond to the same domain as the sender. Any inconsistencies may indicate a fraudulent email.
- Sandboxing is a more advanced technique. It involves opening email attachments or links in a controlled environment to observe their behavior

without risking the actual system. This allows users or security systems to detect malicious activity safely.

4. Drive by Download Attack

A drive by download attack is a common method used to distribute malware. In this type of attack, the attacker identifies insecure or poorly protected websites and injects malicious scripts into the website code, such as HTTP or PHP components.

These scripts can automatically install malware onto the computer of any user who visits the compromised website. In some cases, the script may redirect the user to another website controlled by the attacker, where the malware is then downloaded without the user's knowledge or consent.



Drive-by download

Drive by download attacks can occur when visiting a website, viewing an email, or interacting with a pop up window. Unlike many other types of cyber attacks, this method does not require the user to take any deliberate action to trigger the attack.

Users do not need to click a download button or open a malicious email attachment to become infected. A drive by download can exploit vulnerabilities in applications, operating systems, or web browsers that have not been properly updated or patched.

To protect against drive by download attacks, users should regularly update their web browsers and operating systems and avoid visiting untrusted or potentially malicious websites. It is advisable to rely on familiar and reputable websites, although even these can sometimes be compromised. Users should also minimize the number of unnecessary programs and applications installed on their devices. The more plug ins and software components present, the greater the number of potential vulnerabilities that attackers can exploit.

5. Password Attacks

Since passwords are the most commonly used mechanism for user authentication in information systems, obtaining passwords is a frequent and effective attack method. Attackers can gain access to passwords in several ways, including observing a user's workspace, intercepting network traffic to capture unencrypted credentials, using social engineering techniques, or gaining unauthorized access to databases that store user credentials.



Tấn công mật khẩu

The final approach to obtaining passwords can be carried out either randomly or systematically:

- Password guessing refers to a random approach in which attackers try different passwords and hope that one will be correct. This method may also involve some logical assumptions, such as trying passwords related to a person's name, job title, interests, or other personal information.
- In a dictionary attack, a predefined list of commonly used passwords is utilized to attempt unauthorized access to a user's system or network. One common method involves obtaining an encrypted password file, applying the same encryption to a list of common passwords, and then comparing the results to identify matches.

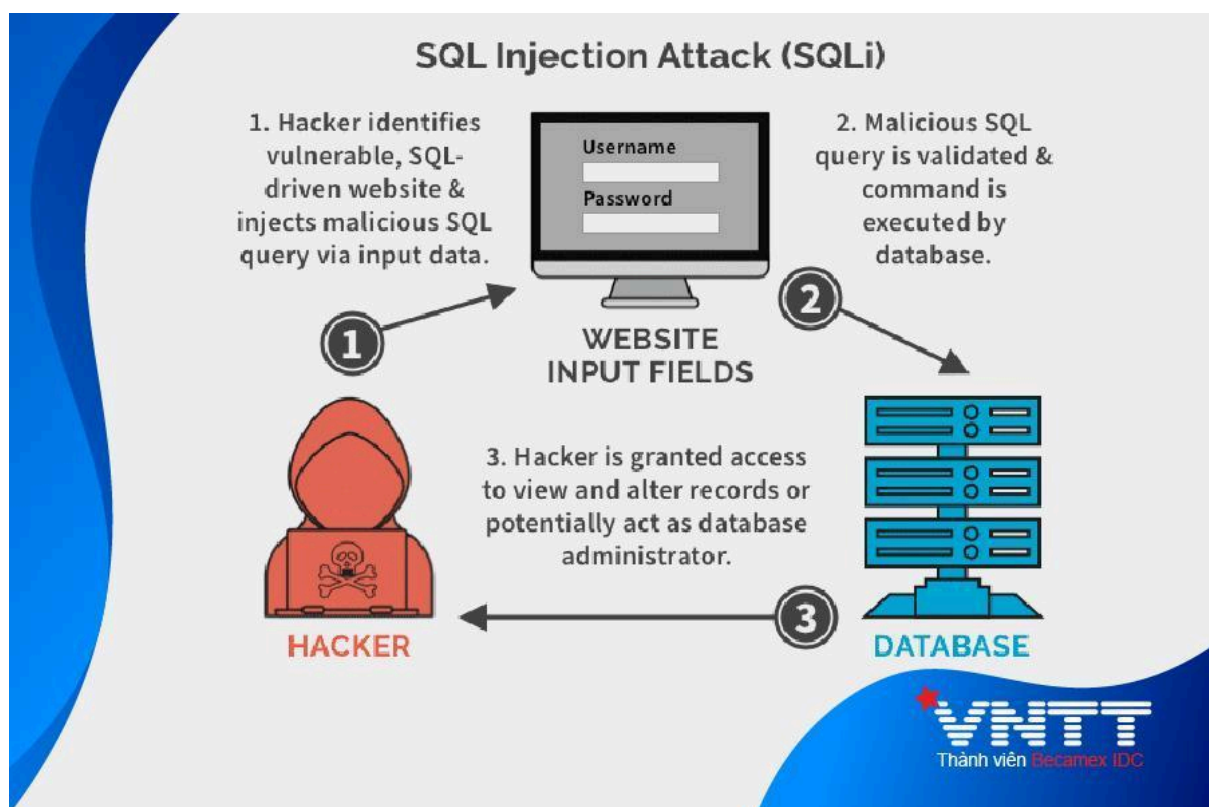
To protect against dictionary and brute force attacks, it is important to implement an account lockout policy. This policy temporarily locks an account after a certain

number of failed login attempts. Following best practices for account lockout configuration helps ensure both security and usability.

6. SQL Injection Attack

SQL injection has become a common issue in database driven websites. It occurs when an attacker executes malicious SQL queries through user input fields that are sent from the client to the server. Instead of providing valid input such as a username or password, the attacker inserts specially crafted SQL commands into the input fields.

These injected commands are then executed by the database, allowing the attacker to manipulate the database, access unauthorized data, or perform other unintended operations.



SQL injection

A successful SQL injection attack can allow an attacker to read sensitive data from the database, modify database contents including inserting, updating, or deleting records,

perform administrative operations such as shutting down the database, retrieve the contents of specific files, and in some cases issue commands to the operating system.

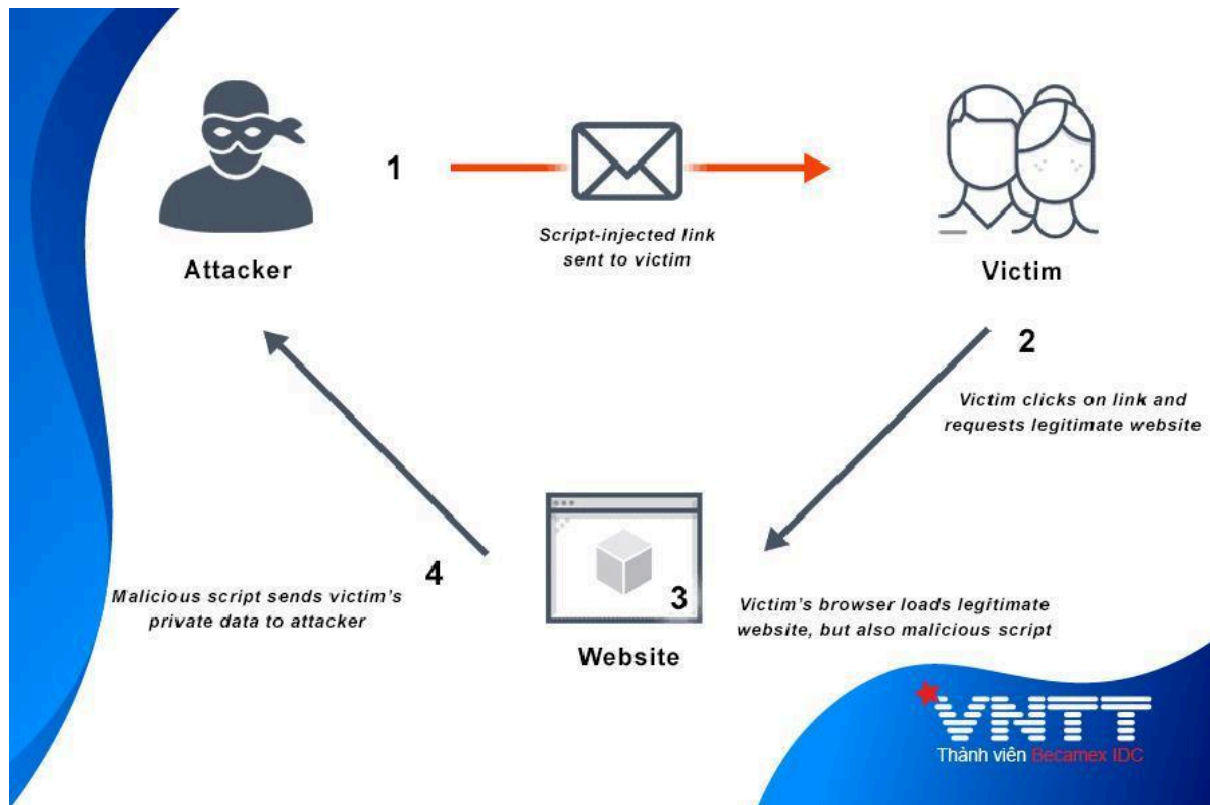
The vulnerability that enables this type of attack arises from the fact that SQL does not clearly distinguish between control instructions and data. As a result, SQL injection is most effective when a web application uses dynamic SQL queries. It is also more commonly found in PHP and ASP applications due to the widespread use of older interfaces. In contrast, applications built with J2EE and ASP.NET are generally less vulnerable because of their more structured and secure programming interfaces.

To protect against SQL injection attacks, it is important to apply the principle of least privilege within the database. Developers should rely on stored procedures that do not include dynamic SQL and use prepared statements or parameterized queries. Additionally, database driven code should be robust enough to validate and sanitize all inputs to prevent malicious queries from being executed.

7. Cross Site Scripting Attack

Cross site scripting attacks exploit web resources to execute malicious scripts within a user's web browser or related applications. In this type of attack, the attacker injects a payload containing malicious JavaScript into a website's database.

When a user requests a page from the affected website, the server returns the page along with the injected payload as part of the HTML content. The user's browser then executes the malicious script, which can lead to data theft, session hijacking, or other harmful actions.



Cross-site scripting (XSS)

For example, an attacker may use a malicious script to send a user's cookies to a server under the attacker's control. The attacker can then extract this information and use it to hijack the user's session. The most severe consequences occur when cross site scripting is used to exploit deeper vulnerabilities. These vulnerabilities may allow attackers not only to steal cookies but also to record keystrokes, capture screenshots, explore and gather network information, and gain remote access to control the user's system.

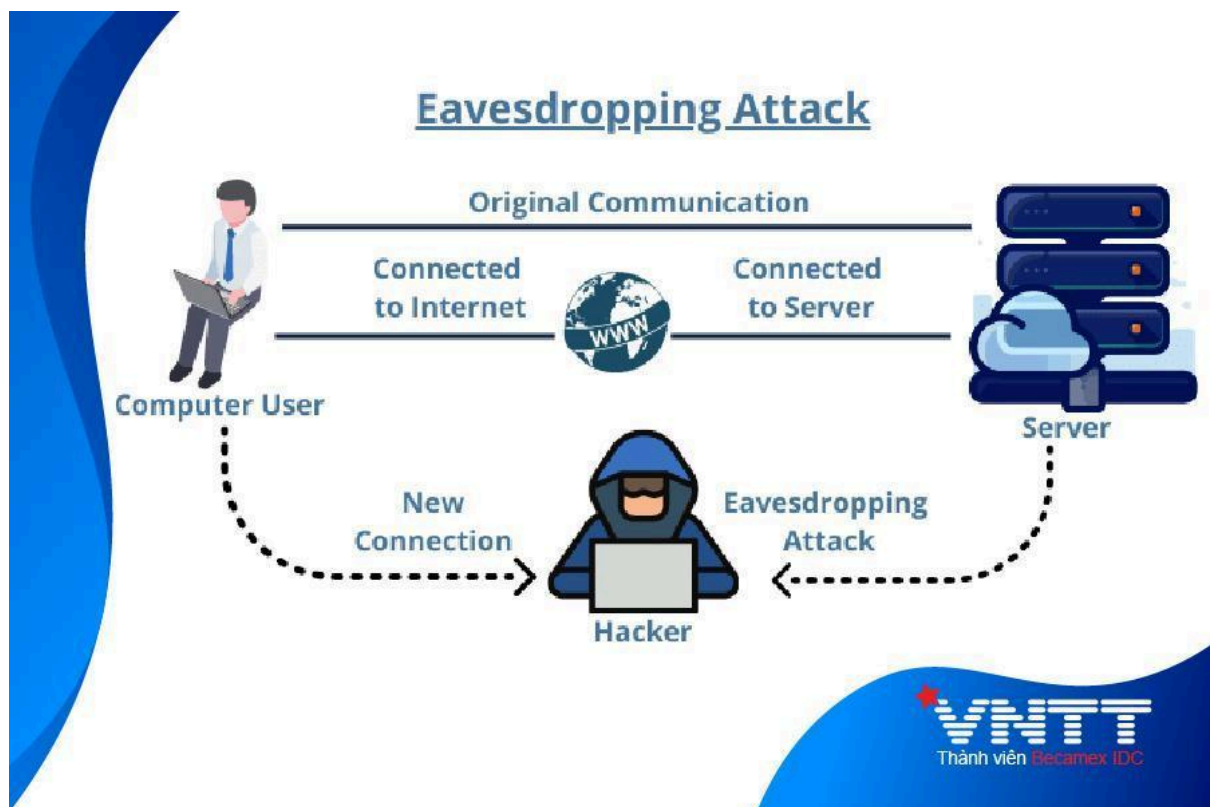
Although cross site scripting can be implemented using technologies such as VBScript, ActiveX, and Flash, JavaScript is the most commonly exploited due to its widespread support across web browsers.

To protect against cross site scripting attacks, developers should filter and validate user input in HTTP requests before sending responses. All data must be properly validated, sanitized, or encoded before being returned to the user. For example, values from query parameters should be carefully processed before being displayed. Special

characters such as question marks, ampersands, forward slashes, angle brackets, and spaces should be converted into their corresponding HTML or URL encoded forms. Additionally, users may be provided with options to disable client side scripting when appropriate.

8. Eavesdropping Attack

Eavesdropping attacks occur when an attacker intercepts network traffic. By monitoring communications, the attacker can capture sensitive information such as passwords, credit card numbers, and other confidential data transmitted over the network.



Eavesdropping Attack

Eavesdropping attacks can be either passive or active.

- Passive eavesdropping occurs when an attacker gathers information by simply listening to data transmissions over a network without altering them.

- Active eavesdropping involves the attacker actively attempting to obtain information by impersonating a trusted entity and sending queries to communication endpoints. This process is often referred to as probing, scanning, or spoofing.

Detecting passive eavesdropping attacks is generally more challenging and often more critical than detecting active attacks. This is because active attacks typically require prior knowledge about trusted entities, which is often obtained through earlier passive eavesdropping activities.

Encryption is the most effective countermeasure against eavesdropping attacks, as it ensures that intercepted data cannot be easily understood or exploited by attackers.